

Manual 55 — Gobierno de terceros, proveedores y cadena de suministro de IA

Fuente controlada de publicación — es-419

Propósito

Establecer un marco práctico para gobernar proveedores de IA, modelos alojados, agentes, complementos, conectores, servidores MCP, proveedores de datos, subprocesadores y demás dependencias de la cadena de suministro durante selección, contratación, incorporación, operación, cambio, incidentes y salida. Deben distinguirse requisitos legales, obligaciones contractuales, expectativas supervisoras, marcos voluntarios y guías comunitarias.

TP-01 — Inventario y materialidad

Mantener inventario completo de proveedores, servicios, modelos, API, agentes, complementos, fuentes de datos, dependencias de alojamiento y cuartas partes; clasificar por criticidad, autonomía, sensibilidad de datos, consecuencia, concentración, sustituibilidad y exposición regulatoria.

TP-02 — Debida diligencia previa

Evaluar propiedad, viabilidad financiera, seguridad, privacidad, gobierno de IA, historial de incidentes, documentación, alojamiento, subcontratistas, continuidad y disponibilidad de evidencia.

TP-03 — Aseguramiento técnico y de seguridad

Evaluar control de acceso, aislamiento de inquilinos, cifrado, vulnerabilidades, desarrollo seguro, abuso de modelos/API, registros, monitoreo, respuesta a incidentes y evidencia independiente proporcional al riesgo.

TP-04 — Privacidad y restricciones de uso de datos

Documentar usos permitidos, entrenamiento/ajuste, retención, eliminación, uso secundario, transferencias, datos sensibles, subprocesadores y evidencia de devolución/eliminación al salir.

TP-05 — Transparencia de modelo, versión y cambio

Exigir identificación de versiones materiales, cambios de arquitectura, obsolescencia, cambios de comportamiento y controles de seguridad, con notificación suficiente para activar revalidación interna.

TP-06 — Subprocesadores y cuartas partes

Identificar dependencias materiales y establecer visibilidad, aprobación, notificación, obligaciones de flujo descendente y controles de continuidad/salida basados en riesgo.

TP-07 — Alojamiento, residencia y transferencias

Mapear regiones, ubicaciones de datos, planos de control, respaldos, conmutación por falla y mecanismos de transferencia; validar compromisos de residencia con evidencia técnica y contractual.

TP-08 — Identidad, autorización y acción delegada

Para agentes, complementos, conectores y proveedores MCP/herramientas, validar identidad, alcance de autorización, mínimo privilegio, autoridad delegada, límites transaccionales, revocación y trazabilidad.

TP-09 — Integridad de la cadena de suministro de IA

Evaluar procedencia de modelos, integridad de paquetes/dependencias, artefactos, imágenes, contenedores, bibliotecas, archivos de modelos, adaptadores, conjuntos de datos, prompts, complementos y canales de actualización; controlar sustitución, manipulación, envenenamiento y cambios no autorizados.

TP-10 — Controles contractuales y derechos de evidencia

Definir cláusulas para seguridad, privacidad, restricciones de uso de IA, acceso a auditoría/evidencia, notificación de incidentes, cambio material, subcontratistas, continuidad, terminación, devolución/eliminación de datos, cooperación y soporte regulatorio cuando corresponda.

TP-11 — Afirmaciones de desempeño y seguridad

Cuestionar afirmaciones materiales de precisión, robustez, seguridad, equidad, privacidad, certificaciones y benchmarks; distinguir evidencia verificada de afirmaciones del proveedor.

TP-12 — Cambio y revalidación

Definir activadores: cambio de modelo/versión, nuevo subprocesador, cambio de alojamiento, falla de control, incidente, cambio de uso de datos, cambio de propiedad, dificultad financiera, regresión material o nuevo requisito aplicable.

TP-13 — Coordinación de incidentes y brechas

Definir plazos de notificación, intercambio de evidencia, roles de contención, comunicaciones, cooperación forense, soporte regulatorio y acciones correctivas.

TP-14 — Riesgo de concentración y dependencia sistémica

Evaluar concentración en un proveedor, dependencias comunes de nube/modelo fundacional, bibliotecas compartidas, proveedores de datos comunes, concentración regional y fallas correlacionadas.

TP-15 — Continuidad, portabilidad y salida

Validar respaldo/restauración, proveedores alternos, portabilidad de datos/modelos, formatos de exportación, migración, revocación de credenciales, eliminación de datos y remoción de dependencias residuales.

TP-16 — Monitoreo continuo

Monitorear señales de riesgo, cambios de servicio, avisos, acciones regulatorias, cambios de versión, degradación de SLA, incidentes, vencimiento de evidencia y hallazgos abiertos.

TP-17 — Excepciones y riesgo residual

Registrar desviaciones aprobadas, justificación, controles compensatorios, propietario de riesgo, vencimiento, activadores de revisión y evidencia de cierre.

TP-18 — Aseguramiento posterior a la salida

Confirmar retiro de acceso, revocación de credenciales, devolución/eliminación de datos, disposición de modelos o adaptadores, efectos sobre subprocesadores, excepciones de retención y preservación de evidencia.

Evidencia requerida

EV-01 inventario/materialidad; EV-02 debida diligencia; EV-03 evidencia de seguridad/privacidad; EV-04 arquitectura/flujo; EV-05 registro de cuartas partes; EV-06 registro de versión/cambio; EV-07 matriz contractual; EV-08 cuestionamiento de afirmaciones; EV-09 playbook de incidentes; EV-10 prueba de continuidad/salida; EV-11 concentración; EV-12 monitoreo; EV-13 excepción; EV-14 terminación/eliminación.

Escenarios

Cambio silencioso de modelo; nuevo país/región; cambio de términos de datos; aumento de permisos; compromiso de dependencia común; afirmación no sustentada; caída crítica sin migración; incidente coordinado; salida sin evidencia completa de eliminación; concentración en un proveedor común.

Regla de liberación

Las afirmaciones del proveedor no son evidencia independiente salvo sustento verificable. La publicación falla cerrada ante defectos sustantivos de fuentes, localización, artefactos, procedencia, renderizado o QA retenida.